Mandate Wallet: scoped agent payments and purchase evidence

Technical documentation | 2026 FinTechathon, Topic F: Agent Wallet

Mandate Labs | Engineering snapshot: 20 October 2026

Abstract

Mandate Wallet allows an owner to delegate a purchasing task to an AI agent within explicit financial limits. A non-upgradeable smart account enforces the payment asset, recipient, approved steps, shared task budget, session budget, per-payment maximum, expiry and revocation. The owner uses a browser workspace and an external wallet. The agent connects through a local Model Context Protocol (MCP) server, including a graphical Claude Desktop extension. A TypeScript gateway handles x402 v2 exact payments, durable orders and recovery.

The demonstrated Base Sepolia case uses native test USDC, Claude Desktop and Rabby. One 0.01 USDC payment settles within a 0.15 USDC task budget and a 0.10 USDC payment maximum. The merchant fails after payment. The gateway recovers delivery with the original order, nonce and settlement transaction. The owner then revokes the session, and the next service request is rejected before a new transaction. The wallet retains 0.14 test USDC.

Signed evidence links disclosed task authority, payment and observed service outcomes. Its guarantees remain explicit: required financial checks passed in this run, while the overall verification report remains incomplete because independent HTTPS provenance and complete unobserved history are not established. The project is a testnet engineering release. No mainnet deployment or independent human security audit is claimed.

1. Product, user and concrete task

An agent can select and call tools, but tool access alone does not define how much money it may spend. Mandate separates tool availability from owner-approved financial authority. Its product consists of the smart account, the owner workspace, an onboarding component, a local gateway with MCP tools, a TypeScript SDK and an independent evidence verifier.

The demonstration asks Claude to purchase an ETH statistics sample and write a short brief. ETH identifies the dataset. USDC is the payment asset throughout the case. The service returns three observations with a mean of 110 from dataset mandate-fixed-fixture-v2. These are fixed artificial samples without market units or timestamps, so the brief cannot treat the mean as a current ETH price.

The owner approves the service, merchant, recipient, exact request, budget, permitted steps and session. After that approval, the agent can execute the permitted purchase without receiving the owner key or requesting a new owner signature for each approved service call. The owner can inspect the outcomes and revoke future authority.

2. End-to-end workflow

The onboarding page retains two paths. Local practice creates an isolated Anvil chain and mock token for experimentation. Testnet mode connects the owner's wallet, prepares account deployment, separates token funding from gas funding, and requests finite task and session authorization. The recorded main flow uses Base Sepolia. It does not require synchronizing a private Ethereum node.

After preparing an account, the user downloads a connection-specific Guided extension and imports it into Claude Desktop. The package references local configuration and avoids the two-file selection required by the advanced manual extension. Claude still requires installation, enablement and applicable tool approvals. The wizard's separate read-only MCP probe checks local connectivity, not whether a model inside Claude has already invoked a tool. Manual MCP configuration for Claude Code and Codex remains available.

The setup sequence diagram in the presentation separates the owner wallet, workspace, gateway, Claude and blockchain. Owner-signed deployment and permission changes precede agent execution. The purchase sequence separates the agent, gateway, merchant, facilitator and blockchain. The gateway obtains a current 402 quote, registers the exact payment, waits for confirmation, and only then releases its payment signature. Delivery and result checks follow settlement.

The recorded session lasted two hours. Each individual payment authorization has a separate immutable maximum validity of 300 seconds. Extending a session does not extend a previously registered payment. An expired order is preserved as evidence and cannot be replaced by silently changing its nonce. An owner-approved new task was used after an earlier order expired in the same funded wallet.

3. Components and trust boundaries

Component	Responsibility	Trust and authority boundary
Owner and Rabby	Review and sign deployment, funding, task, session and revocation intents.	The owner must verify decoded scope. The gateway and agent do not load the owner private key.
Mandate workspace	Display account identity, permissions, services, payments and evidence.	A displayed request is not an applied chain change. A matching signed receipt and event must confirm it.
MandateAccount	Enforce registered payment digests, root/session reservations, expiry and revocation.	Correct deployed code, token behavior and canonical chain state are assumptions. Owner and asset are fixed.
Session signer	Sign registrations and exact payments within approved scope.	A compromised session key remains subject to on-chain limits, but can bypass optional off-chain controller gates.
Local gateway	Authenticate a fixed connection, validate quotes, persist orders and reconcile transactions.	Local file permissions are not isolation from an administrator or another process running as the same user.
Merchant and facilitator	Supply the configured service and submit the exact token settlement.	The tested pair is controlled by the team. Marketplace presence does not establish trust or compatibility.

Component	Responsibility	Trust and authority boundary
Evidence verifier	Check disclosed evidence with separately supplied trust configuration and RPC data.	The bundle cannot establish its own trust root. Missing provenance or history must remain incomplete.

Purchase amounts use six-decimal USDC atomic units. Gas is accounted for separately in native ETH. The controlled fixture does not charge an additional facilitator service fee. Root budgets are independent on each chain. There is no cross-chain aggregate budget guarantee.

4. Authorization and financial protocol

A root mandate commits to the task, total budget, per-payment maximum, expiry, approved merchants and business steps. A step binds an exact request hash and merchant. A session selects a signer and an approved step subset, with its own budget, maximum, expiry, policy version and epoch. Replacement preserves occupied amounts and used steps while invalidating prior sessions. Revoked identifiers cannot be reactivated.

Registration uses an EIP-712 message binding the mandate and version, session and epoch, business step, merchant, request and quote hashes, recipient, amount, validity and deterministic nonce. The signature domain binds the chain and wallet. A separately configured merchant signer binds the quote to its concrete payment terms.

The step nonce is keccak256(abi.encode(chainId, wallet, mandateId, stepId)). It does not change with the agent, session or policy version. The account permanently records a used step. Retrying the same task therefore cannot create a second registration by choosing another session or changing the version.

The client persists the intent, registers the payment and waits for canonical confirmation before signing the token authorization. During token settlement, ERC-1271 accepts only a matching registered, unreleased and currently authorized commitment with the expected session signature and an unused token nonce. Actual settlement rechecks live authority. Prior facilitator preverification cannot override a subsequent revocation.

Occupied budget equals registered amounts minus safely released amounts. Paid, pending and uncertain commitments continue to occupy budget. A commitment may release automatically only after its payment expires and the token nonce remains unused. A used or canceled nonce is not evidence of successful transfer or a refund. Release does not make the business step reusable.

Reservation is an authorization ledger rather than cash escrow. The owner can withdraw tokens, and multiple roots can authorize more than the current token balance. The gateway checks available cash before a new purchase, but the chain's actual settlement remains authoritative. Failed transactions can consume gas even when no procurement payment succeeds.

5. Supported payment route and merchant discovery

The implemented route is x402 v2 exact with EIP-3009, a deployed ERC-1271 account and the tested token/facilitator behavior. Base Sepolia uses native test USDC. The historical Ethereum Sepolia Mandate experiments use an explicitly controlled token fixture. Base mainnet compatibility inspection is read-only. Permit2 and ERC-7710 are not supported automatic payment routes in this release.

The compatibility work retains both the original Echo EIP-7702 comparison and the deployed ERC-1271 route. Token proxy implementations, domain behavior and signature handling are part of compatibility evidence. An untested wallet/token/facilitator combination must not inherit the selected route's acceptance.

Bazaar supplies candidate service metadata. It does not expand owner authority. The client validates the actual 402 response, network, asset, integer price, payee, resource, request and configured facilitator. Catalog descriptions remain untrusted input. They cannot authorize a different address, read private configuration or add a new paid step. The demonstration does not claim a purchase from an arbitrary third-party Bazaar merchant.

6. Durable execution, recovery and result interpretation

The durable order identity is chain, wallet, mandate and business step. SQLite uniqueness, compare-and-swap transitions and worker leases preserve intent and transaction identity. The client persists signed operations before broadcast. An RPC timeout first triggers reconciliation of the original hash and nonce. It does not trigger a new payment authorization.

Reorg recovery checks canonical block hashes and can restore the original transaction. Evidence retains the prior history and appends observations for the recovered canonical payment. Prolonged RPC failure or a consumed but unexplained nonce can leave an order unresolved and its budget occupied. Availability is not guaranteed by conservative accounting.

The user sees payment, delivery and result as separate states. A paid transaction can coexist with a failed HTTP response. An HTTP 200 can coexist with invalid data. In the recorded case, the first response failed after settlement. Recovery reused the same payment and returned valid fixed data. Revocation then blocked the unused BTC step before registration, with no new transaction.

7. Evidence and research questions

The previous proposal motivates three questions: how to bind an action to approved policy, what minimum evidence supports delegated-session accountability, and which host interference can be detected despite replay, delay, grinding or suppression. Mandate adds the asynchronous payment problem: shared budgets must remain safe across concurrent registrations, uncertain settlement and revocation.

Versioned PolicySpec, PaymentCommitment, ActionProof, SessionAttestation and ContainmentDecisionLog schemas distinguish implemented fields from proposed extensions. Salted Merkle disclosures bind selected fields to ordered signed checkpoints. ActionProof links the evidence to the exact registration and payment digests. The current account does not enforce an entire off-chain session root.

The separate verifier checks disclosed signatures and links, exact request scope, runtime and owner authority at registration, root reservation events, canonical token AuthorizationUsed and Transfer events, configured merchant claims and fixed-result predicates. A standard merchant receipt signs resource, payer and settlement identity. It does not sign the amount, request body or result body in this schema. Those facts need their separate evidence sources.

Required financial checks passing does not make the overall report complete. Session signatures do not establish an independent HTTPS transcript. A valid unanchored prefix does not prove that the host disclosed its entire history. Minimal disclosure hides some data and necessarily leaves corresponding checks incomplete. Public chain amounts, recipients and timing remain visible.

An optional reference controller enforces a scope and query cap at its interface and retains known checkpoint roots. Comparing an export against a separately trusted latest root can detect an omitted retained tail. Direct session-key use bypasses this off-chain controller. The same-host experiment does not protect keys or retention from the machine administrator. An optional TLSNotary example concerns a separate compatible public API and a same-host notary/prover, not the paid demonstration merchant.

8. Evaluation and interpretation

The M7 protocol mandate-m7-r2 uses seed 0x40271015. Four HTTP configurations each execute ten controlled cases with three repetitions, giving 30 tasks per group. B1 is an ordinary EOA reference with honest local spend controls. B2 adds the Mandate account. B3 adds evidence and separate verification. B4 adds the same-host controller. The repaired Echo swap reference is evaluated separately because it performs a different task.

All 120 HTTP tasks eventually reached paid, returned and valid after explicit recovery where required. They produced 132 settlements with zero duplicate payments. These are eventual outcomes. The logs retain injected HTTP failures and three shared-registration-signer nonce conflicts per Mandate group.

Group, n=30	Gas/task P50 / P95	Purchase ms P50 / P95	Full task ms P50 / P95
B1 EOA	84922 / 152732	25.49 / 46.16	27.33 / 48.03
B2 Mandate	572438 / 1110664	51.46 / 95.25	55.72 / 99.89
B3 plus evidence	572438 / 1110664	72.86 / 131.56	317.94 / 619.94
B4 plus controller	572438 / 1110664	115.82 / 213.08	399.33 / 752.50

Nearest-rank quantiles use the raw mixed task rows. Full task time includes applicable export and separate verification. Setup is excluded. Nested phase timings must not be added. These local measurements are not public-network latency or a production SLA. The added registration transaction costs more gas than the EOA reference.

A separate generated dataset contains 10,000 distinct explicitly invalid eth_call inputs, with 20 categories of 500 and six legal controls. It records generation predicates, seed and outcomes. These are not 10,000 mined attacks or a statistical guarantee for all hostile inputs. Stateful experiments cover eight core financial/controller cases and evidence interference. Contract fuzz and independent balance/reservation invariants complement these scoped tests. Static tools produced 113 initial review signals, with one repaired Echo GCM-tag policy issue and 112 retained dispositions. This is not an independent human audit.

The Oct 19 recording repairs separately passed 82 related TypeScript regressions and type checking. Dated historical suite counts must not be added to newer counts as if they represented distinct coverage. Clean-source reproduction for the public snapshot is recorded in the accompanying source acceptance report.

9. Public execution evidence

The demonstration account is 0xa794DAa86ff10920B75a4de3b0E752586e8703D2 on Base Sepolia, chain 84532. The asset is native test USDC at 0x036CbD53842c5426634e7929541eC2318f3dCF7e. The payment is 10000 atomic units. The final observed balance is 140000 atomic units.

Settlement transaction: https://sepolia.basescan.org/tx/0xc23d943b69c94a5a8468ab32ee9b454ab6b57f7681ba4b93f16e4d58ae840c5d

Session revocation: https://sepolia.basescan.org/tx/0x5ba3feb1febde1fc2637c524ac031aa17e0a9f583bf39fc843bb865162d69a6e

The exported evidence contains receipts, logs, separate gas and L1 fees, service outcomes, refusal evidence and a verifier trust file. Two RPC providers reported all eight key transactions below their common finalized height of 48325041 at observation. This remains a trusted-RPC observation rather than an independent consensus proof.

The standalone report has requiredChecksPassed=true and overall=incomplete. The workspace verification button lacked a trusted profile during recording. No successful button verification is claimed. The picture edit uses genuine UI captures with cuts, crops, scaling and held views. It is not a synchronized uninterrupted screen recording. User voice-over remains a separate production step.

10. Echo, originality and remaining work

Echo v2 provides repaired operation-bound signatures, consistent swap decoding, exact allowance management, actual input-spend accounting and real EntryPoint/strict Alto receipt handling. Mandate implements a separate EIP-3009 purchase route with reservation accounting and durable service recovery. Echo actual swap spend and Mandate occupied budget have different meanings.

The research proposal contributes the accountability and host-interference questions. Its full intended guarantees, desired success rates, TEE or zero-knowledge extensions are not implemented claims here. Public upstream source and licenses are retained. Registration files, private proposal originals, personal configuration and signing material are excluded from source publication.

Remaining product work includes signed installation and updates, persistent local-node recovery, remaining operating-system and wallet usability paths, broader tested merchant/facilitator compatibility and an external human security audit. T12 remains 7/8 and the original T0-T11 checklist remains 97/105. Preparing these files does not close G3 or the final competition submission gate.

11. Reproduction and references

Source repository: https://github.com/MandateLabs666/mandate-wallet . The source README and BUILD_AND_DEPLOY.en.md describe frozen dependencies, local build, tests, onboarding and the independent verifier. Read-only verification of the recorded public bundle requires no owner key or new payment. Historical deployments and expired or revoked sessions are evidence, not reusable live purchasing credentials.

Primary implementation: mandate/contracts/src/MandateAccount.sol, mandate/services/client.ts, mandate/services/transactions.ts, mandate/gateway/mcp.ts, mandate/evidence/verifier.ts and mandate/onboarding/engine.ts.

Experiment sources: planning/M2_ACCEPTANCE.zh-CN.md, planning/M3_ACCEPTANCE.zh-CN.md, planning/M7_BENCHMARK_ACCEPTANCE.zh-CN.md, planning/M7_DATASET_ACCEPTANCE.zh-CN.md, planning/M7_FORMAL_BOUNDARIES.zh-CN.md and planning/M8_ACCEPTANCE.zh-CN.md. Raw audits: artifacts/m7/benchmarks/audit.json and artifacts/m7/research/dataset-audit.json.

Current run: competition/video/claude-desktop-base-v1/execution-evidence/. Public standards and upstream references: https://www.x402.org/ , https://github.com/coinbase/x402 , https://eips.ethereum.org/EIPS/eip-1271 , https://eips.ethereum.org/EIPS/eip-3009 , https://eips.ethereum.org/EIPS/eip-712 .

Competition requirements and remaining organizer questions are recorded in artifacts/competition/. Preparing this package does not constitute organizer approval or official submission.